

DIGIZAFE — MEMBER 5 MASTER VIVA NOTES

Member 5 Role

Explainable Risk Scoring, Analytics & Security Dashboard

A strong way to describe your contribution:

"My primary area was the risk-analysis and presentation layer of DigiZafe. I worked on converting raw breach and exposure telemetry into an interpretable risk score, categorizing the severity, explaining why the score was produced, and presenting the results through the security dashboard so that even a non-technical user can understand the required action."

The project explicitly aims to move beyond a binary **breached/not breached** result toward severity interpretation and actionable mitigation.

PART I — THE PROBLEM YOU SOLVE

Traditional breach systems say:

Email found in breach

↓
YES

But that doesn't answer:

How serious?

Why serious?

How recent?

What information was exposed?

What should I do?

DigiZafe changes this to:



The presentation explicitly frames DigiZafe around answering:

"How exposed am I, why, and what should I do?"

PART II — WHAT IS RISK SCORING?

Risk scoring converts multiple exposure indicators into a numerical representation of risk.

Instead of:

Breached = TRUE

we want:

Risk Score = 82

Severity = HIGH

and then:

Why?

Recent breach

+

Password exposure

+

Repeated compromise

+

High severity

followed by:

Action:

Change password

Enable MFA

Review affected accounts

PART III — RAW DATA → RISK SCORE

The overall process is:

External Intelligence



Raw Telemetry



Normalization



Feature Extraction



Risk Engine



Score



Severity



Explanation



Dashboard

The research architecture explicitly describes telemetry being normalized before being processed by the risk-assessment engine and subsequently visualized in the dashboard.

PART IV — WHAT FEATURES ARE IMPORTANT?

The project considers factors such as:

1. Breach frequency

How many times the identifier has appeared in exposure events.

2. Breach severity

How serious the exposed information is.

3. Recency

How recently the exposure occurred.

4. Password exposure

Whether authentication information was involved.

5. Repeated compromise / reuse

Whether the same credential appears repeatedly.

These factors form the basis of credential-vulnerability assessment.

PART V — WHY RECENCY MATTERS

Suppose:

User A:
Breach = 2012

User B:
Breach = 2026

A simple system might treat them identically.

DigiZafe instead considers temporal recency.

The documented model uses:

$$T = \max(F, 1 - \lambda A)$$

where:

A = age of newest breach

λ = decay coefficient

F = minimum decay floor

So older events can have reduced influence.

PART VI — CREDENTIAL VULNERABILITY

The documented model calculates:

$$V_{\text{cred}} = (B + M) \times T \times R$$

where:

B = exposure severity weight

M = breach/frequency multiplier

T = temporal decay

R = repeated compromise multiplier

This is much more meaningful than:

number of breaches = risk

PART VII — IDENTITY VISIBILITY

DigiZafe doesn't only look at passwords.

It also considers:

Public profiles

Professional identity

Location information

Publicly indexed exposure surfaces

This produces:

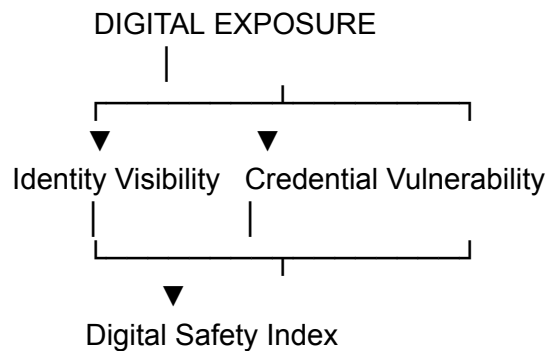
Videntity

The research defines identity visibility separately from credential vulnerability.

PART VIII — THE TWO RISK AXES

This is one of the **most important concepts** for Member 5.

DigiZafe uses:



The two dimensions are evaluated independently before being combined.

PART IX — DIGITAL SAFETY INDEX

The documented formula is:

$$DSI = 100 - (0.40 \times V_{identity} + 0.60 \times V_{cred})$$

So:

40%

Identity Visibility

60%

Credential Vulnerability

PART X — WHY 60% FOR CREDENTIAL VULNERABILITY?

Professor:

"Why did you give credential vulnerability more weight?"

Answer:

"Because the model considers exposed authentication material to represent a generally more immediate threat than passive public visibility. Therefore credential vulnerability receives a 60% contribution while identity visibility receives 40%."

PART XI — IMPORTANT:

DSI IS NOT JUST AN ML PREDICTION

This is a very important viva distinction.

The core research model is:

Deterministic Risk Assessment

rather than simply:

Black-box ML

The project emphasizes interpretable and deterministic scoring because the user should understand **why** a particular risk level was generated.

PART XII — EXPLAINABILITY

Imagine the dashboard says:

Risk Score: 87

That's not enough.

Instead:

Risk Score: 87
Severity: CRITICAL

Contributing factors:

- ✓ Recent credential breach
- ✓ Password exposure detected
- ✓ Multiple historical compromises
- ✓ High breach severity

Recommended:

- Change affected passwords
- Avoid password reuse
- Enable MFA

This is what makes the result actionable.

The research explicitly says that numerical scores are supplemented with deterministic explanations and actionable security guidance.

PART XIII — WHY EXPLAINABILITY?

Professor:

"Why not just show the number?"

Answer:

"A numerical score alone doesn't tell the user what caused the risk. Explainability maps the underlying exposure factors to human-readable reasons and recommendations, allowing the user to understand and act on the result."

PART XIV — RISK TIERS

The dashboard translates numerical results into qualitative severity levels.

Conceptually:

LOW



MEDIUM

↓
HIGH
↓
CRITICAL

The exact displayed thresholds should be taken from the implemented configuration/version being demonstrated; don't invent different thresholds during the viva.

PART XV — WHY RISK TIERS?

Users understand:

HIGH

more easily than:

Vcred = 73.48

So the dashboard provides:

Numerical score

+

Severity category

+

Explanation

+

Recommendation

PART XVI — THE DASHBOARD

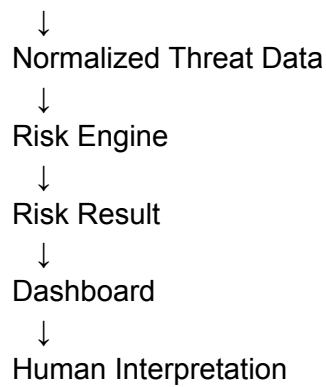
The dashboard's purpose is not simply visualization.

It is an:

interpretation layer

Architecture:

Backend



The research paper describes the final investigation report being presented through an interactive dashboard containing exposure indicators, recommendations and credential-management capabilities.

PART XVII — WHAT SHOULD THE DASHBOARD SHOW?

A useful investigation view contains:

DIGITAL SAFETY INDEX		
72		
HIGH		
Identity Visibility	61	
Credential Vulnerability	79	
Exposure Factors		
• Recent breach		
• Password exposure		
• Multiple compromises		
Recommended Actions		
• Change password		
• Enable MFA		
• Review affected accounts		

PART XVIII — WHY VISUALIZATION MATTERS

Security telemetry can be extremely difficult for ordinary users to interpret.

For example:

BreachCount = 8

Recency = 12

Severity = 4

Reuse = 3

isn't intuitive.

The dashboard converts that into:

HIGH RISK

Reason:

Recent and repeated credential exposure.

Action:

Change the affected password immediately.

PART XIX — THE ML VERSION

One of the project versions also describes a hybrid explainable-AI dashboard.

That version converts breach telemetry into a **six-feature vector** and evaluates it using:

Transparent Rule Engine

+

Gradient Boosting Regression Model

The recorded comparison reports Gradient Boosting as having the lowest MAE of **2.10 points** and the highest risk-tier accuracy of **91.48%** among the listed models.

Important

If your defense is based on the deterministic-paper version, **do not casually replace its risk model with this ML version.**

There are multiple DigiZafe versions in the source library, so you should describe the exact version your team is submitting.

PART XX — WHY USE SYNTHETIC DATA?

Real leaked credentials are problematic because they can contain:

Real passwords

Real emails

Real personal information

The ML-oriented paper therefore uses a:

right-skewed synthetic dataset

to imitate realistic exposure patterns without storing real compromised credential pairs.

This is a strong answer if the professor asks:

"Why didn't you train on actual leaked passwords?"

Answer:

"Because using real compromised credential pairs creates privacy, legal and security concerns. We therefore used synthetic data designed to reproduce realistic exposure distributions without retaining actual compromised credentials."

PART XXI — WHAT IS RIGHT-SKEWED DATA?

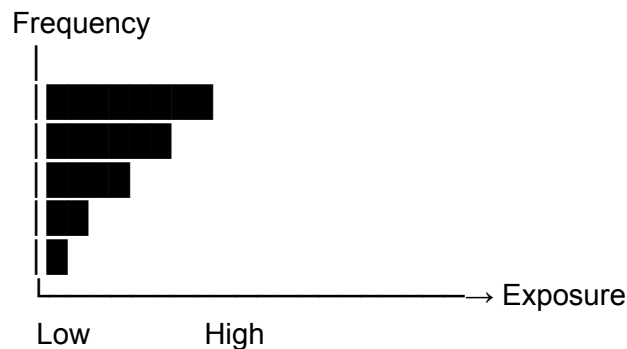
Security exposure is not normally uniformly distributed.

Usually:

Many users → relatively low exposure

Few users → extremely high exposure

Graphically:



That's why a right-skewed distribution is more realistic than uniform synthetic data.

PART XXII — GRADIENT BOOSTING

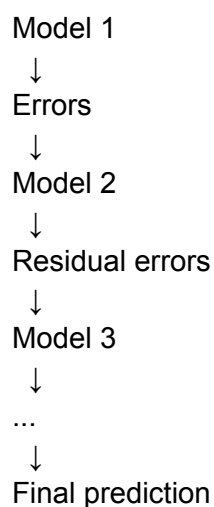
If your professor asks:

"Explain Gradient Boosting."

Answer:

"Gradient Boosting builds an ensemble sequentially. Each new weak learner focuses on reducing the errors made by the previous ensemble. The learners are combined to produce a stronger predictive model."

Conceptually:



PART XXIII — WHY GRADIENT BOOSTING?

It works well for structured/tabular data and can model nonlinear relationships between exposure features and risk.

The documented ML experiment compares it with:

Ridge Regression
Decision Tree
Random Forest
Gradient Boosting

with Gradient Boosting achieving the best recorded performance in that experiment.

PART XXIV — MAE

The ML version reports:

MAE = 2.10

MAE means:

Mean Absolute Error

Formula:

$$\text{MAE} = (1/n) \sum |y_{\text{actual}} - y_{\text{predicted}}|$$

If:

Actual = 80

Predicted = 77

error:

$$|80 - 77| = 3$$

MAE averages this absolute difference over the dataset.

PART XXV — WHY MAE?

Because the risk output is numerical.

MAE directly answers:

"On average, how far is the predicted risk score from the actual/reference score?"

Lower is better.

PART XXVI — RISK-TIER ACCURACY

The system also evaluates whether the predicted score falls into the correct risk tier.

For example:

Actual:
HIGH

Prediction:
HIGH

→ Correct

The recorded experiment reports **91.48% risk-tier accuracy** for Gradient Boosting.

PART XXVII — DETERMINISTIC VS ML

Very likely viva question.

**Deterministic
model**

Explicit rules

ML model

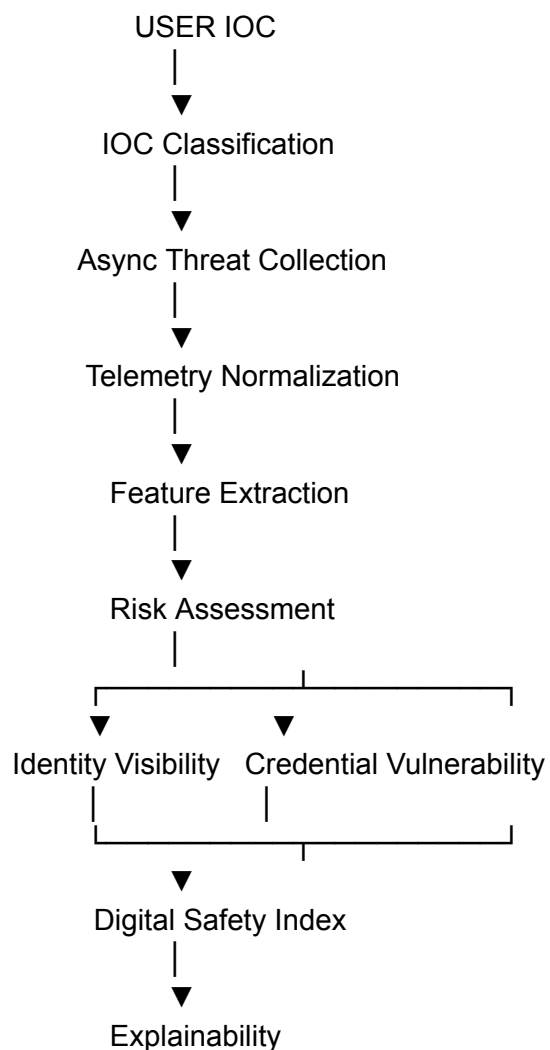
Learns patterns

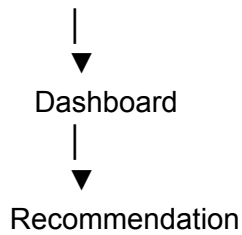
Highly interpretable	Can require explanation
Reproducible	Data-dependent
Easy to audit	Needs evaluation
No training required	Requires training data

The project materials contain both approaches in different versions, so be precise about which version you are presenting.

PART XXVIII — SECURITY DASHBOARD PIPELINE

Your complete pipeline:





This follows the documented investigation workflow from IOC classification through asynchronous collection, normalization, risk assessment, persistence and visualization.

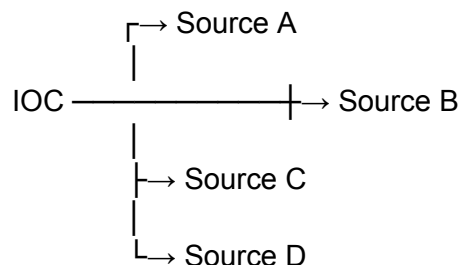
PART XXIX — ASYNCHRONOUS COLLECTION

Another important component of the architecture:

Instead of:



DigiZafe uses concurrent/asynchronous intelligence collection:



The paper describes concurrent external intelligence queries using asynchronous HTTP communication.

PART XXX — WHY ASYNC?

Because external services are network-bound.

Sequential:

$$T = T1 + T2 + T3 + T4$$

Concurrent:

$$T \approx \max(T1, T2, T3, T4)$$

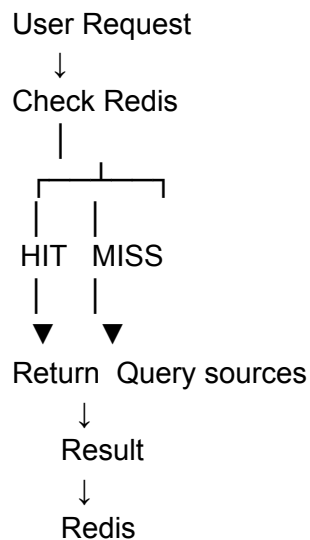
assuming independent requests and sufficient resources.

This reduces waiting time.

PART XXXI — REDIS

DigiZafe also uses Redis-assisted caching.

Conceptually:



The research architecture explicitly describes Redis caching of investigation results to improve responsiveness.

PART XXXII — WHY CACHE SECURITY DATA?

Because the same IOC may be investigated repeatedly.

Without cache:

Request
↓
External APIs
↓
Wait

With cache:

Request
↓
Redis HIT
↓
Immediate response

Benefits:

- lower latency
 - reduced external API usage
 - improved responsiveness
 - reduced redundant work
-

PART XXXIII — ENTITY RESOLUTION

Threat intelligence sources may describe the same entity differently.

Example:

Source A:
username = user123

Source B:
handle = user123

Source C:
profile = /user123

The system needs to determine whether these observations refer to the same candidate entity.

This is:

Entity resolution / identity correlation

The research pipeline explicitly includes correlation/entity resolution before risk assessment.

PART XXXIV — WHY NORMALIZATION?

Different APIs produce different formats.

For example:

API A:

```
{  
  "breachCount": 5  
}
```

and:

API B:

```
{  
  "breaches": 5  
}
```

The platform converts them into a common representation:

Unified Telemetry

```
{  
  breach_count: 5  
}
```

This makes downstream risk calculation much simpler.

PART XXXV — WHY EXPLAINABLE SECURITY?

Suppose two users receive:

Risk = 80

Without explanation, the user doesn't know why.

With explanation:

Risk = 80

Because:

- recent exposure
- password involved
- repeated compromise

The second result is actionable.

PART XXXVI — RECOMMENDATION ENGINE

The final stage translates risk into action:

Risk



Rules



Recommendation

Example:

Password exposed



Change password

Password reused



Generate unique password

MFA disabled



Enable MFA

This closes the loop:

Detection



Interpretation



Mitigation

PART XXXVII — YOUR DASHBOARD ANSWER

Professor:

"What is the purpose of your dashboard?"

Answer:

"The dashboard is not just a visualization layer. It is the interpretation layer between the analytical engine and the user. It converts raw threat telemetry and numerical risk calculations into severity levels, contributing factors and actionable remediation recommendations."

PART XXXVIII — 30 VIVA QUESTIONS

Q1. What was your contribution?

Risk analysis, explainability and dashboard presentation — converting heterogeneous exposure data into an interpretable security assessment and actionable recommendations.

Q2. What is risk scoring?

Converting multiple exposure indicators into a numerical representation of security risk.

Q3. Why not just use breach count?

Because severity, recency, credential exposure and repeated compromise affect the actual risk.

Q4. What are the two axes?

Identity Visibility and Credential Vulnerability.

Q5. What is DSI?

Digital Safety Index, the composite measure derived from those two risk dimensions.

Q6. Give the DSI formula.

$$DSI = 100 - (0.40V_{identity} + 0.60V_{cred})$$

Q7. Why 40/60?

Credential vulnerability is considered the more immediate threat.

Q8. What is temporal decay?

A mechanism that reduces the influence of older exposure events over time.

Q9. What is Vcred?

Credential vulnerability score.

Q10. What affects Vcred?

Severity, breach frequency, recency/temporal decay and repeated compromise.

Q11. Why deterministic scoring?

Explainability, reproducibility and auditability.

Q12. Why explainability?

So the user knows why the system assigned a particular risk level.

Q13. Why use asynchronous requests?

To query multiple intelligence sources concurrently and reduce network waiting time.

Q14. Why Redis?

To cache investigation results and reduce latency and repeated external queries.

Q15. What is normalization?

Converting heterogeneous source responses into a common internal telemetry representation.

Q16. What is entity resolution?

Correlating observations from different sources to determine whether they refer to the same candidate entity.

Q17. What is Gradient Boosting?

A sequential ensemble method where new weak learners reduce the errors of the previous ensemble.

Q18. Why Gradient Boosting?

It is effective for structured/tabular data and can model nonlinear relationships.

Q19. What was the recorded MAE?

2.10 points in the documented ML experiment.

Q20. What was the risk-tier accuracy?

91.48% for Gradient Boosting in that documented experiment.

Q21. What is MAE?

Mean Absolute Error — the average absolute difference between predicted and reference values.

Q22. Why synthetic data?

To avoid storing or training on real compromised credential pairs and the associated privacy/legal risks.

Q23. Why right-skewed synthetic data?

Because real-world exposure is not uniformly distributed; most users have relatively limited exposure while a smaller group has much larger exposure.

Q24. Why have a dashboard instead of raw JSON?

Raw JSON is difficult for non-specialists to interpret. The dashboard converts analytical results into understandable security information.

Q25. What happens after scoring?

The score is categorized, explained and converted into actionable recommendations.

Q26. What is alert fatigue?

Users becoming desensitized to large numbers of undifferentiated security alerts.

The project specifically motivates contextual risk scoring as a way to address this problem.

Q27. How does temporal decay help alert fatigue?

It prevents old exposures from being treated exactly like recent exposures, improving prioritization.

Q28. What happens if two sources provide conflicting data?

The system should normalize and correlate source observations rather than blindly treating every observation as independent evidence.

Q29. Why cache investigation results?

To avoid repeated expensive external intelligence requests and improve response time.

Q30. What is the ultimate goal of the scoring system?

Not merely to produce a number, but to prioritize exposure and tell the user what action should be taken.

PART XXXIX — HARD PROFESSOR QUESTIONS

"Why is a score of 80 meaningful?"

Answer:

"The numerical score is meaningful only in the context of the defined scoring model and its contributing factors. It is not intended to represent an absolute probability of compromise."

Very important.

Don't say:

"80 means there is an 80% chance of hacking."

That is incorrect unless the model has specifically been calibrated as a probability model.

"Is your risk score a probability?"

No. It is a risk index/score, not automatically a probability.

"Can an old breach still matter?"

Yes. Temporal decay reduces its influence but does not necessarily eliminate it because the model includes a minimum decay floor.

"Why does password exposure matter more?"

Because credential compromise can directly enable account takeover, whereas some forms of public visibility may primarily increase reconnaissance or social-engineering exposure.

"What if a user has many old breaches?"

The system should consider recency and severity rather than simply treating the number of breaches as proportional risk.

"What if the user has only one recent severe breach?"

That can still result in substantial credential vulnerability because severity and recency contribute independently.

"Why use logarithmic scaling?"

One of the later DigiZafe versions describes logarithmic volume scaling specifically to prevent alert saturation.

Answer:

"Because raw exposure counts can grow rapidly. Logarithmic scaling reduces the dominance of very large counts and prevents the score from saturating simply because one user has accumulated many exposure records."

PART XL — LOGARITHMIC SCALING

Suppose:

User A → 2 exposures

User B → 20 exposures

User C → 200 exposures

Linear scaling:

2
20
200

can make large counts dominate the entire score.

Log scaling behaves more gradually:

$\log(3)$
 $\log(21)$
 $\log(201)$

This compresses the range.

The V4 material explicitly identifies logarithmic risk computation as one of its four execution phases.

PART XLI — RATE LIMITING

The V4 architecture also includes backend rate limiting.

Why?

Attacker
↓
Thousands of requests
↓
External APIs / Backend
↓
Resource exhaustion

Rate limiting helps restrict excessive requests.

PART XLII — RBAC

Another architectural component is:

Role-Based Access Control

Conceptually:

User



Role



Permissions

The dual-persona version describes:

Enterprise SOC Admin

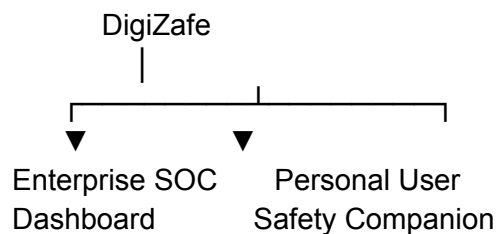
+

Personal Digital Safety User

with separate interfaces.

PART XLIII — ENTERPRISE VS PERSONAL VIEW

The later architecture describes two personas:



The enterprise view focuses more on:

Incidents

Threat intelligence

Operational monitoring

while the personal view focuses on:

Digital exposure

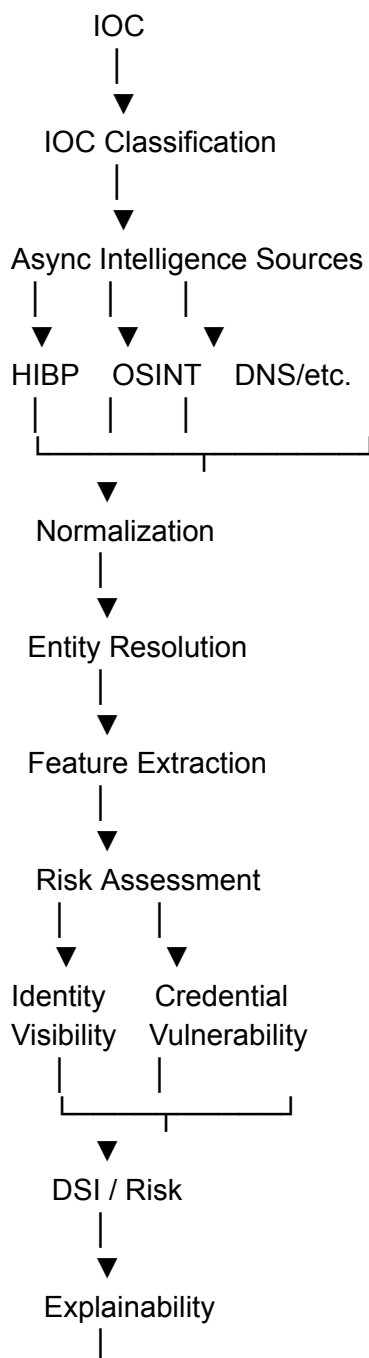
Credential safety

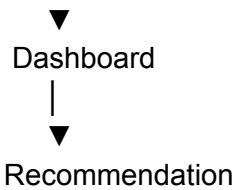
Recommendations

The documented dual-persona architecture explicitly uses RBAC to serve these two interfaces.

PART XLIV — COMPLETE MEMBER 5 ARCHITECTURE

Memorize this:





PART XLV — YOUR 5-MINUTE VIVA ANSWER

If the professor asks:

"Explain your contribution."

Say:

"My primary contribution was in the risk-analysis and security-dashboard layer of DigiZafe. The main problem we wanted to solve was that traditional breach-checking tools provide mostly binary results, such as whether an identifier appeared in a breach, without explaining how serious the exposure actually is.

DigiZafe therefore processes heterogeneous exposure telemetry and extracts factors such as breach severity, frequency, recency, credential exposure and repeated compromise. The system separates exposure into two dimensions: Identity Visibility and Credential Vulnerability. These are evaluated independently and then combined into the Digital Safety Index using the documented deterministic model.

The important part of my contribution is explainability. Instead of showing only a numerical score, the dashboard presents the severity, the factors contributing to the score and the recommended action. This makes the output understandable to a non-technical user.

The architecture also uses asynchronous threat-intelligence collection and Redis caching so that multiple sources can be queried efficiently and previously obtained investigation results can be reused.

In the ML-oriented version, the project additionally experimented with a six-feature representation and compared Ridge, Decision Tree, Random Forest and Gradient Boosting models. Gradient Boosting achieved the recorded MAE of 2.10 and risk-tier accuracy of 91.48 percent.

So my overall contribution connects the backend intelligence and risk engine to the end user: converting raw exposure data into an interpretable risk assessment and actionable security decision."

PART XLVI — 60-SECOND VERSION

Memorize this:

"I worked mainly on the risk-analysis and dashboard side of DigiZafe. My role was to convert heterogeneous breach and OSINT telemetry into an interpretable security assessment. We separate risk into Identity Visibility and Credential Vulnerability, consider factors such as severity, frequency, recency and repeated compromise, and combine them into the Digital Safety Index.

The important part is explainability: instead of showing only a score, the dashboard tells the user what caused the risk and what action should be taken. The platform also uses asynchronous intelligence collection and Redis caching for responsiveness. In the ML-oriented version, we evaluated multiple models and Gradient Boosting achieved the recorded MAE of 2.10 and risk-tier accuracy of 91.48%.

So my contribution essentially connects threat intelligence and risk computation to an understandable, actionable security dashboard."

PART XLVII — 10 THINGS MEMBER 5 MUST KNOW

● 1.

Risk score $\neq$ probability of being hacked.

● 2.

Know the two axes:

Identity Visibility

Credential Vulnerability

● 3.

Know:

$$DSI = 100 - (0.40V_{identity} + 0.60V_{cred})$$

● 4.

Know:

$$V_{cred} = (B + M) \times T \times R$$

● 5.

Know temporal decay:

$$T = \max(F, 1 - \lambda A)$$

● 6.

Understand **why** recency matters.

● 7.

Understand **why** explainability matters.

● 8.

Know why asynchronous collection is used.

● 9.

Know why Redis is used.

● 10.

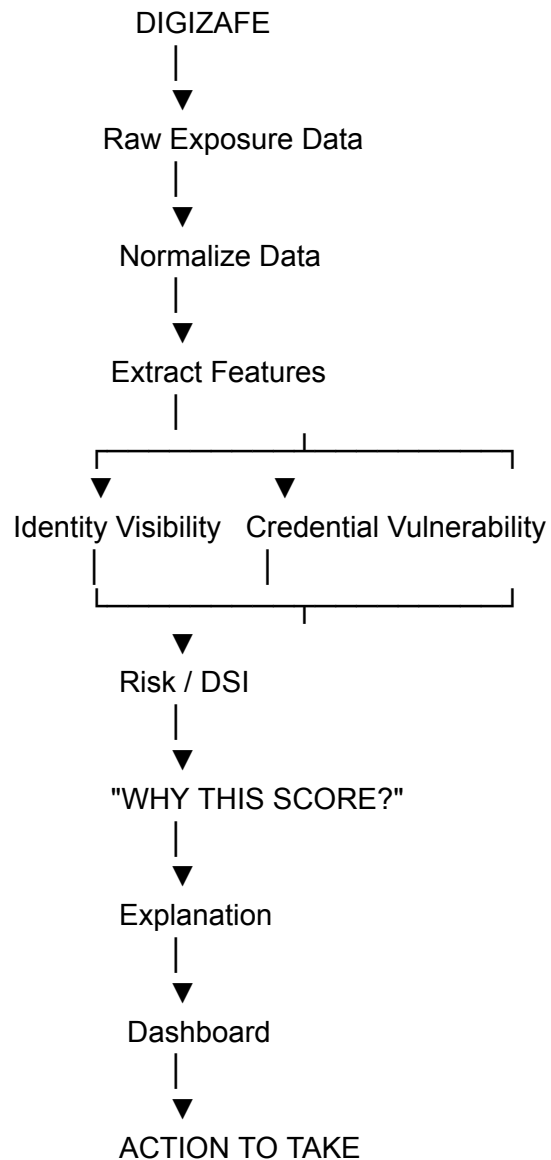
If presenting the ML version, memorize:

Gradient Boosting

MAE = 2.10

Risk-tier accuracy = 91.48%

FINAL MEMBER 5 MENTAL MODEL



Strongest one-line answer for Member 5:

"I worked on converting DigiZafe's heterogeneous exposure intelligence into an explainable risk assessment and actionable dashboard, connecting the risk engine's output to understandable severity, contributing factors and remediation guidance."